

Sécurité et gestion des risques

Support de cours autonome — Partie 1 : CISSP Domaine 1, modélisation des menaces et synthèse des présentations

Yulliwas AMEUR

Sup de Vinci Rennes · Séances des 8 et 9 septembre 2026

Comment lire ce support

1

Les définitions

Chaque notion importante est posée dans un encadré « Définition ». Apprenez-les : ce sont les mots de l'examen et du métier.

2

Les encadrés colorés

« À retenir » résume l'idée clé. « Exemple » montre la notion dans une situation réelle.

3

Les termes anglais

Le CISSP est en anglais. Le terme anglais est donné entre parenthèses pour vous aider à lire la documentation.

4

La révision

À la fin : les 10 idées clés, un glossaire et un quiz corrigé pour vérifier vos acquis.

À RETENIR Lisez les chapitres dans l'ordre : chaque chapitre utilise le vocabulaire du précédent.

À la fin de cette partie, vous saurez...

Expliquer

- La triade CIA et les grands principes de sécurité
- Le rôle de la gouvernance et des politiques
- Les obligations légales (RGPD, NIS2...)

Calculer et décider

- Évaluer un risque de façon qualitative ou quantitative
- Calculer SLE, ALE et la valeur d'une contre-mesure
- Choisir un traitement du risque

Choisir une méthode

- Distinguer les modèles de menaces (STRIDE, PASTA...)
- Choisir le bon modèle selon le contexte
- Combiner plusieurs modèles

Onze chapitres, du vocabulaire à la pratique

N°	Chapitre	Question à laquelle il répond
01	Concepts fondamentaux	Que veut dire « sécuriser » une information ?
02	Gouvernance et politiques	Qui décide, et comment l'écrit-on ?
03	Légal, réglementaire, conformité	Quelles règles faut-il respecter ?
04	Sécurité du personnel	Comment gérer le risque humain ?
05	Gestion des risques	Comment mesurer et traiter un risque ?
06	Modélisation des menaces	Comment trouver ce qui peut mal tourner ?
07	Chaîne d'approvisionnement	Et les risques venant des fournisseurs ?
08	Sensibilisation et formation	Comment faire progresser les personnes ?
09	Continuité d'activité	Comment continuer à fonctionner après un incident ?
10	Synthèse des modèles de menaces	Que retenir des présentations du 9 septembre ?
11	Réviser	Ai-je bien compris ?

Le CISSP

En anglais : Certified Information Systems Security Professional

DÉFINITION

Certification internationale délivrée par l'ISC2. Elle valide la capacité à concevoir, mettre en œuvre et piloter un programme de sécurité de l'information. Son contenu est décrit dans un référentiel appelé CBK.

CBK

Common Body of Knowledge : le « corpus commun de connaissances », découpé en 8 domaines.

PRÉREQUIS

5 ans d'expérience dans au moins 2 des 8 domaines (ou « Associate of ISC2 » en attendant).

À RETENIR

Le CISSP forme des managers de la sécurité, pas seulement des techniciens.

Les 8 domaines et leur poids à l'examen

Domaine	Intitulé	Poids
1	Sécurité et gestion des risques (Security and Risk Management)	16 %
2	Sécurité des actifs (Asset Security)	10 %
3	Architecture et ingénierie de la sécurité	13 %
4	Sécurité des communications et des réseaux	13 %
5	Gestion des identités et des accès (IAM)	13 %
6	Évaluation et tests de sécurité	12 %
7	Opérations de sécurité	13 %
8	Sécurité du développement logiciel	10 %

À RETENIR Ce support couvre le Domaine 1, le plus lourd : il donne le vocabulaire de tous les autres.

Penser comme un conseiller de la direction

La sécurité sert le métier

La sécurité n'est pas une fin en soi. Elle protège la mission et les objectifs de l'organisation.

La vie humaine d'abord

Face à un choix, la sécurité des personnes passe toujours avant les données et les biens.

Le risque, pas le zéro risque

Le risque zéro n'existe pas. On cherche un risque acceptable, à un coût raisonnable.

La direction décide

Le professionnel de la sécurité conseille. La direction prend la décision et en porte la responsabilité.

À RETENIR À l'examen, la « meilleure » réponse est souvent la plus managériale, pas la plus technique.

Quatre canons, dans un ordre de priorité

Tout certifié s'engage à respecter ce code. En cas de conflit entre deux canons, **le premier l'emporte**.

Ordre	Canon	En clair
1	Protéger la société, le bien commun, la confiance du public et les infrastructures	L'intérêt général passe avant tout
2	Agir de façon honorable, honnête, juste, responsable et légale	Être intègre et respecter la loi
3	Fournir un service diligent et compétent à ses mandants	Bien servir son employeur ou ses clients
4	Faire progresser et protéger la profession	Partager, former, défendre le métier

À RETENIR En cas de dilemme, appliquez les canons dans l'ordre : la société, puis l'honnêteté, puis l'employeur, puis la profession.

01

CHAPITRE 01

Concepts fondamentaux

Le vocabulaire de base de toute la sécurité de l'information.

- La triade CIA et son inverse (DAD)
- Authenticité et non-répudiation
- Identification, authentification, autorisation, traçabilité
- Les grands principes de conception

DÉFINITION DE BASE

Sécurité de l'information

En anglais : Information Security

DÉFINITION

Ensemble des mesures qui protègent l'information, quel que soit son support (papier, numérique, oral), contre l'accès non autorisé, la modification, la destruction ou l'indisponibilité.

ATTENTION

Sécurité de l'information $\neq$ cybersécurité. La cybersécurité se limite au monde numérique ; la sécurité de l'information inclut aussi le papier et la parole.

EXEMPLE

Un contrat imprimé oublié sur une photocopieuse est un problème de sécurité de l'information.

La triade CIA : trois propriétés à protéger

C • Confidentiality

Confidentialité

Seules les personnes autorisées peuvent **lire** l'information.

I • Integrity

Intégrité

L'information reste **exacte et complète** : elle n'est modifiée que par des personnes autorisées.

A • Availability

Disponibilité

L'information est **accessible** aux personnes autorisées, au moment où elles en ont besoin.

À RETENIR Chaque mesure de sécurité protège au moins une de ces trois propriétés. Posez-vous toujours la question : « laquelle ? »

Empêcher la divulgation non autorisée

Menaces

- Écoute du réseau (sniffing)
- Vol de mot de passe
- Ingénierie sociale
- Erreur d'envoi d'un e-mail

Mesures

- Chiffrement des données
- Contrôle d'accès
- Classification de l'information
- Formation du personnel

Notions liées

- **Sensibilité** : gravité d'une divulgation
- **Discrétion** : choix de limiter la diffusion
- **Secret** : obligation de ne pas divulguer

EXEMPLE Un fichier client publié par erreur sur un site web est une atteinte à la confidentialité.

Empêcher la modification non autorisée

Menaces

- Modification d'un virement
- Virus qui altère des fichiers
- Erreur de saisie
- Injection SQL

Mesures

- Fonctions de hachage
- Signatures numériques
- Contrôle des versions
- Validation des saisies

Trois objectifs

- Empêcher les modifications non autorisées
- Empêcher les erreurs des utilisateurs autorisés
- Garder la cohérence interne et externe

EXEMPLE Un hacker qui change le montant d'une facture dans la base de données porte atteinte à l'intégrité.

Garantir l'accès au bon moment

Menaces

- Dénî de service (DoS, DDoS)
- Panne matérielle
- Rançongiciel
- Catastrophe naturelle, coupure électrique

Mesures

- Redondance (RAID, grappes de serveurs)
- Sauvegardes testées
- Plan de continuité
- Protection anti-DDoS

Mesure clé

- On mesure souvent la disponibilité en pourcentage de temps de service.
- 99,9 % $\approx$ 8 h 45 d'arrêt par an
- 99,99 % $\approx$ 53 min par an

EXEMPLE Un site de vente en ligne bloqué par une attaque DDoS le jour des soldes subit une atteinte à la disponibilité.

DAD : ce que fait l'attaquant

Le modèle **DAD** décrit les trois façons de « casser » la triade CIA. Il aide à raisonner en attaquant.

Propriété protégée	Atteinte (DAD)	Définition
Confidentialité	Divulgaration (Disclosure)	L'information est révélée à une personne non autorisée.
Intégrité	Altération (Alteration)	L'information est modifiée sans autorisation.
Disponibilité	Destruction (Destruction)	L'information ou le service est détruit ou rendu inaccessible.

À RETENIR CIA = ce que l'on protège. DAD = ce que l'on veut empêcher.

Deux propriétés complémentaires

Authenticity

Authenticité

Garantie que l'information ou la personne est bien **celle qu'elle prétend être**. On vérifie l'origine.

Nonrepudiation

Non-répudiation

Impossibilité pour une personne de **nier** avoir réalisé une action (envoi, signature, paiement). Elle repose souvent sur la signature numérique.

À RETENIR Avec la triade CIA, ces deux propriétés forment les « 5 piliers » de l'assurance de l'information (*Information Assurance*).

IAAA : de « qui êtes-vous ? » à « qu'avez-vous fait ? »

1

Identification

L'utilisateur **annonce** qui il est. Exemple : il saisit son identifiant.

2

Authentification

Le système **vérifie** cette identité. Exemple : mot de passe, badge, empreinte.

3

Autorisation

Le système décide **ce que** l'utilisateur a le droit de faire.

4

Traçabilité

Les actions sont **enregistrées** et rattachées à la personne (journaux, audit).

À RETENIR La traçabilité (*Accountability*) n'est possible que si chaque personne a un identifiant unique : pas de comptes partagés.

Quatre principes à connaître par cœur

Least privilege

Moindre privilège

Chaque personne ou programme reçoit **uniquement les droits nécessaires** à sa mission, et pas plus.

Need to know

Besoin d'en connaître

Même avec le bon niveau d'habilitation, on n'accède à une information que si **son travail l'exige**.

Separation of duties

Séparation des tâches

Une tâche sensible est **partagée entre plusieurs personnes**, pour qu'aucune ne puisse frauder seule.

Defense in depth

Défense en profondeur

On empile **plusieurs couches** de protection : si l'une tombe, les autres tiennent.

EXEMPLE Séparation des tâches : celui qui crée un fournisseur dans le logiciel comptable n'est pas celui qui valide son paiement.

D'autres principes utiles

Principe	Définition simple
Sécurité par défaut	Le réglage de départ est le plus sûr (tout fermé, puis on ouvre ce qui est utile).
Défaillance sécurisée	En cas de panne, le système se met dans un état sûr (fail secure).
Simplicité (KISS)	Un système simple a moins de failles et se contrôle plus facilement.
Confiance zéro	On ne fait confiance à personne par défaut, même à l'intérieur du réseau (Zero Trust).
Confiance mais vérification	On accorde l'accès, mais on contrôle régulièrement son usage (Trust but verify).
Protection de la vie privée dès la conception	La vie privée est prise en compte dès le début d'un projet (Privacy by Design).

À RETENIR Attention : « fail secure » protège les biens (porte verrouillée) ; « fail safe » protège les personnes (porte ouverte en cas d'incendie).

IDÉE CLÉ DU CHAPITRE 01

La sécurité est un équilibre entre protection, facilité d'usage et coût.

Trop de sécurité bloque le travail et coûte cher. Pas assez expose l'organisation. Le rôle du responsable sécurité est de trouver le bon niveau pour chaque information.

02

CHAPITRE 02

Gouvernance et politiques

Qui décide de la sécurité, qui la met en œuvre, et comment on l'écrit.

- Gouvernance et management
- Rôles et responsabilités
- Due care et due diligence
- Cadres de référence (ISO, NIST, COBIT)
- La pyramide documentaire

Gouvernance et management : ne pas confondre

Governance

Gouvernance

- Fixe la **direction** : « quoi » et « pourquoi »
- Portée par le conseil d'administration et la direction générale
- Définit les objectifs, l'appétence au risque, les priorités
- Surveille les résultats

Management

Management

- Organise la **mise en œuvre** : « comment »
- Porté par les responsables opérationnels (RSSI, DSI...)
- Planifie, construit, exploite, mesure
- Rend compte à la gouvernance

À RETENIR La gouvernance de la sécurité est une partie de la gouvernance d'entreprise : elle doit être alignée sur la stratégie de l'organisation.

Trois horizons de planification

Long terme

Plan stratégique

Horizon **3 à 5 ans**. Définit la mission et les grands objectifs de sécurité. Révisé chaque année.

Moyen terme

Plan tactique

Horizon **environ 1 an**. Découpe la stratégie en projets : budget, recrutement, déploiement d'outils.

Court terme

Plan opérationnel

Horizon **court** (semaines, mois). Décrit les tâches concrètes, les procédures, les calendriers.

EXEMPLE Stratégie : « sécuriser le cloud d'ici 2029 ». Tactique : « déployer le MFA en 2027 ». Opérationnel : « activer le MFA pour le service RH en mars ».

Qui fait quoi dans la sécurité ?

Rôle	Responsabilité principale
Direction générale	Responsable en dernier ressort de la sécurité. Valide la politique et le budget.
RSSI (CISO)	Pilote le programme de sécurité et conseille la direction.
Propriétaire des données	Cadre dirigeant qui classe les données et décide qui y accède (Data Owner).
Dépositaire des données	Applique au quotidien les protections décidées : sauvegardes, droits (Custodian).
Utilisateur	Utilise les données dans le respect des règles.
Auditeur	Vérifie de façon indépendante que les contrôles fonctionnent.
DPO	Délégué à la protection des données : veille au respect du RGPD.

À RETENIR On peut déléguer une tâche, jamais la responsabilité finale : elle reste à la direction.

Due care et due diligence

Réfléchir

Due diligence

« Faire ses devoirs » : **se renseigner, analyser, planifier** avant d'agir. C'est la connaissance et la préparation.

Agir

Due care

« Faire preuve de prudence » : **agir** comme le ferait une personne raisonnable, en mettant en place les protections. C'est l'action.

À RETENIR Moyen mnémotechnique : Diligence = Découvrir (on étudie). Care = Concrétiser (on agit). Ne pas faire les deux peut constituer une négligence.

Des moments où le risque change

Fusions et acquisitions

- Évaluer la sécurité de l'entreprise rachetée
- Intégrer ses systèmes avec prudence
- Aligner les politiques

Cessions

- Séparer les systèmes et les accès
- Effacer ou transférer les données
- Révoquer les comptes partagés

Comités de gouvernance

- Réunissent métier, juridique, IT et sécurité
- Arbitrent les priorités et les budgets
- Suivent les indicateurs de risque

À RETENIR Toute réorganisation (rachat, vente, nouveau fournisseur) doit déclencher une nouvelle évaluation des risques.

Les principaux référentiels de sécurité

Référentiel	Éditeur	À quoi sert-il ?
ISO/IEC 27001	ISO	Exigences pour un système de management de la sécurité (SMSI). Certifiable.
ISO/IEC 27002	ISO	Catalogue de 93 mesures de sécurité (guide de bonnes pratiques).
NIST CSF 2.0	NIST (États-Unis)	Cadre simple en 6 fonctions pour piloter la cybersécurité.
NIST SP 800-53	NIST	Catalogue très détaillé de contrôles de sécurité.
COBIT 2019	ISACA	Gouvernance et management des systèmes d'information.
ITIL	Axelos / PeopleCert	Bonnes pratiques de gestion des services informatiques.

À RETENIR Un référentiel est un modèle : on l'adapte à son organisation, on ne le copie pas tel quel.

Six fonctions pour piloter la cybersécurité

1 Gouverner
Fixer la stratégie, les rôles, les politiques.

2 Identifier
Connaître ses actifs et ses risques.

3 Protéger
Mettre en place les protections.

4 Détecter
Repérer les attaques et anomalies.

5 Répondre
Agir face à un incident.

6 Rétablir
Revenir à la normale et tirer les leçons.

À RETENIR La fonction « Gouverner » (Govern) est la nouveauté de la version 2.0 : elle entoure les cinq autres.

Le SMSI et la roue de Deming (PDCA)

SMSI (Système de Management de la Sécurité de l'Information) : ensemble organisé de politiques, processus et mesures pour gérer la sécurité de façon continue.

P

Plan • Planifier

Définir le périmètre,
analyser les risques,
choisir les mesures.

D

Do • Réaliser

Mettre en œuvre les
mesures et former les
personnes.

C

Check • Vérifier

Mesurer, auditer, revoir les
résultats.

A

Act • Améliorer

Corriger les écarts et
améliorer en continu.

À RETENIR La certification ISO 27001 prouve qu'un SMSI existe et fonctionne. Elle ne prouve pas que l'entreprise est « inviolable ».

Cinq types de documents, du général au détaillé

Document	Définition	Obligatoire ?
Politique (Policy)	Intentions de la direction, de haut niveau : le « pourquoi ».	Oui
Norme (Standard)	Règle précise et obligatoire : le « quoi ».	Oui
Référentiel minimal (Baseline)	Niveau de sécurité minimal pour un type de système.	Oui
Procédure (Procedure)	Étapes détaillées, pas à pas : le « comment ».	Oui
Ligne directrice (Guideline)	Conseil ou recommandation pour bien faire.	Non

À RETENIR Seules les lignes directrices sont facultatives. Tous les autres documents doivent être respectés.

Les mots de passe, du plus général au plus détaillé

Document	Exemple concret
Politique	« L'accès aux systèmes de l'entreprise est protégé par une authentification forte. »
Norme	« Les mots de passe font au moins 14 caractères. Le MFA est obligatoire à distance. »
Référentiel minimal	« Tout poste Windows applique le profil de durcissement CIS niveau 1. »
Procédure	« Pour réinitialiser un mot de passe : 1) vérifier l'identité, 2) ... »
Ligne directrice	« Utilisez une phrase de passe facile à retenir, par exemple quatre mots. »

À RETENIR La politique change rarement ; la procédure change souvent. C'est pour cela qu'on les sépare.

03

CHAPITRE 03

Légal, réglementaire et conformité

Les règles externes que l'organisation doit respecter.

- Conformité et familles de droit
- Cybercriminalité et propriété intellectuelle
- Import-export et flux de données
- Vie privée et RGPD
- NIS2, DORA et autres textes
- Types d'enquêtes

DÉFINITION

Conformité

En anglais : Compliance

DÉFINITION

Fait de respecter les exigences qui s'imposent à l'organisation : lois, règlements, contrats et normes internes. La conformité se prouve : il faut pouvoir montrer des preuves (documents, journaux, audits).

CONFORMITÉ LÉGALE

Imposée par la loi. Exemple :
RGPD, NIS2.

CONFORMITÉ CONTRACTUELLE

Imposée par un contrat. Exemple
: PCI DSS exigé par les réseaux de
cartes bancaires.

À RETENIR

Être conforme ne veut pas dire
être sécurisé : la conformité est
un minimum.

Trois grandes catégories de lois

Deux grands systèmes juridiques existent : la **common law** (pays anglo-saxons, basée sur la jurisprudence) et le **droit civil** (France, Europe continentale, basé sur des codes écrits).

Catégorie	Objet	Exemple
Droit pénal (Criminal law)	Punit les atteintes à la société. Sanctions : amende, prison.	Intrusion dans un système (art. 323-1 Code pénal)
Droit civil (Civil law)	Règle les litiges entre personnes ou entreprises. Sanction : dommages et intérêts.	Non-respect d'un contrat d'hébergement
Droit administratif / réglementaire	Règles fixées par les autorités pour un secteur.	Sanction de la CNIL pour non-respect du RGPD

Quand l'informatique est la cible ou l'outil

Système ciblé

L'ordinateur est la **victime** : intrusion, rançongiciel, déni de service.

Système utilisé

L'ordinateur est l'**outil** : fraude, escroquerie, harcèlement en ligne.

Système accessoire

L'ordinateur contient des **preuves** d'un crime classique.

À RETENIR Difficultés : l'attaquant peut être dans un autre pays (compétence), cacher son identité (attribution) et effacer ses traces (preuves).

Protéger les créations de l'esprit

Protection	Ce qui est protégé	Durée (repère)
Droit d'auteur (Copyright)	L'expression d'une œuvre : texte, code source, musique	Vie de l'auteur + 70 ans
Brevet (Patent)	Une invention nouvelle et industrielle	20 ans, puis domaine public
Marque (Trademark)	Un nom, un logo, un signe distinctif	10 ans, renouvelable sans limite
Secret des affaires (Trade secret)	Information confidentielle à valeur économique	Tant qu'elle reste secrète

À RETENIR Un secret des affaires n'est protégé que si l'entreprise prend des mesures raisonnables pour le garder secret (NDA, contrôle d'accès).

Le droit d'utiliser un logiciel

Type de licence	Définition
Contractuelle	Contrat écrit et signé entre l'éditeur et le client.
Sous film plastique (shrink-wrap)	Acceptée en ouvrant l'emballage du logiciel.
Par clic (click-through)	Acceptée en cliquant sur « J'accepte » lors de l'installation.
Abonnement cloud	Droit d'usage d'un service en ligne, lié à un contrat et un paiement récurrent.
Open source	Code accessible et modifiable, selon des conditions (GPL, MIT, Apache...).

À RETENIR Utiliser plus de licences que celles achetées expose l'entreprise à des sanctions : l'inventaire logiciel est une mesure de conformité.

Certaines technologies sont contrôlées

Arrangement de Wassenaar

Accord international (1996) sur le contrôle des exportations d'armes et de **biens à double usage** (civil et militaire), dont certains produits de chiffrement.

Règles européennes

Le règlement (UE) 2021/821 encadre l'export des biens à double usage depuis l'Union européenne.

Règles américaines

ITAR (armement) et EAR (biens commerciaux et à double usage) s'appliquent aux produits d'origine américaine.

À RETENIR Avant d'envoyer un produit de chiffrement ou un logiciel de sécurité à l'étranger, il faut vérifier les règles d'export.

Les données personnelles ne voyagent pas librement

Le principe

Le RGPD interdit de transférer des données personnelles hors de l'Union européenne, **sauf** si un niveau de protection suffisant est garanti.

Les outils

- **Décision d'adéquation** : le pays est jugé sûr par la Commission
- **Clauses contractuelles types** (CCT)
- **Règles d'entreprise contraignantes** (BCR)

Le cas des États-Unis

Le Privacy Shield a été annulé en 2020 (arrêt Schrems II). Le Data Privacy Framework l'a remplacé en 2023.

À RETENIR Héberger des données clients chez un fournisseur cloud étranger est un transfert : il faut vérifier sa base légale.

Les définitions du RGPD

Terme	Définition
Donnée personnelle	Toute information qui identifie une personne, directement ou indirectement (nom, IP, photo...).
Donnée sensible	Santé, opinions politiques, religion, orientation sexuelle, biométrie... Protection renforcée.
Traitement	Toute opération sur des données : collecte, stockage, consultation, suppression...
Responsable de traitement	Organisme qui décide pourquoi et comment les données sont traitées.
Sous-traitant	Organisme qui traite les données pour le compte du responsable.

À RETENIR Anonymisation = irréversible : les données ne sont plus personnelles. Pseudonymisation = réversible : le RGPD s'applique toujours.

Les grands principes du traitement

Principe	En clair
Licéité, loyauté, transparence	Une base légale, et une information claire des personnes
Limitation des finalités	Un objectif précis, annoncé à l'avance
Minimisation	Seulement les données nécessaires
Exactitude	Des données justes et mises à jour
Limitation de la conservation	Une durée de conservation définie
Intégrité et confidentialité	Des données protégées (sécurité)
Responsabilité (accountability)	Pouvoir prouver que l'on respecte tout cela

Droits des personnes et obligations des organisations

Droits des personnes

- Accès à ses données
- Rectification
- Effacement (« droit à l'oubli »)
- Opposition et limitation
- Portabilité

Obligations

- Tenir un registre des traitements
- Nommer un DPO (dans certains cas)
- Réaliser une AIPD pour les traitements à risque
- Protéger les données dès la conception

En cas de violation

- Notifier l'autorité (CNIL) en **72 heures**
- Informer les personnes si le risque est élevé
- Sanction : jusqu'à **20 M€ ou 4 %** du chiffre d'affaires mondial

Un paysage réglementaire dense

Texte	Qui est concerné ?	Idée principale
NIS2 (UE)	Entités essentielles et importantes (énergie, santé, transport, numérique...)	Mesures de sécurité et notification des incidents
DORA (UE)	Secteur financier et ses prestataires TIC	Résilience opérationnelle numérique (depuis janv. 2025)
Cyber Resilience Act (UE)	Fabricants de produits numériques	Sécurité des produits tout au long de leur vie
AI Act (UE)	Fournisseurs et utilisateurs de systèmes d'IA	Obligations selon le niveau de risque de l'IA
PCI DSS	Organisations qui traitent des cartes bancaires	Norme contractuelle de protection des données de carte

Chaque enquête a ses règles de preuve

Type	Objectif	Niveau de preuve (tradition US)
Administrative	Problème interne (faute d'un salarié, incident)	Règles internes de l'entreprise
Pénale	Poursuivre une infraction devant un tribunal	Au-delà du doute raisonnable (le plus exigeant)
Civile	Régler un litige entre parties	Prépondérance des preuves (« plus probable qu'improbable »)
Réglementaire	Vérifier le respect d'une réglementation	Variable selon l'autorité

À RETENIR Une enquête administrative peut devenir pénale : il faut dès le départ préserver les preuves (chaîne de possession).

04

CHAPITRE 04

Sécurité du personnel

L'humain est à la fois la première ressource et le premier risque.

- Le cycle de vie de l'emploi
- Recrutement et vérifications
- Contrôles pendant l'emploi
- Départ du salarié
- Prestataires et tiers

Sécuriser avant, pendant et après

Recrutement

Avant

- Description de poste avec les exigences de sécurité
- Vérification des antécédents
- Accord de confidentialité (NDA)

Emploi

Pendant

- Formation et sensibilisation
- Moindre privilège et revue des droits
- Rotation des postes, congés obligatoires

Départ

Après

- Révocation immédiate des accès
- Restitution du matériel
- Rappel des obligations de confidentialité

À RETENIR La plupart des incidents impliquent une erreur ou une action humaine : la sécurité du personnel est un contrôle à part entière.

Recruter en sécurité

Description de poste

Elle précise les responsabilités et le niveau de sensibilité du poste. Plus le poste est sensible, plus les vérifications sont poussées.

Vérification des antécédents

Diplômes, expériences, références.
Elle doit rester **proportionnée** et **légale** (en France : Code du travail et RGPD).

Accords signés

NDA (accord de non-divulgateion),
charte informatique, clause de non-concurrence si nécessaire.

À RETENIR On ne peut pas tout vérifier : les informations demandées doivent avoir un lien direct avec le poste.

Des contrôles pour limiter la fraude et les erreurs

Contrôle	Définition	Ce qu'il permet
Rotation des postes	Changer régulièrement les personnes de poste	Détecter une fraude et éviter la dépendance à une personne
Congés obligatoires	Imposer des congés d'au moins une à deux semaines consécutives	Faire apparaître une fraude cachée
Séparation des tâches	Partager une tâche sensible entre plusieurs personnes	Empêcher la fraude par une seule personne
Revue des accès	Vérifier régulièrement les droits de chacun	Éviter l'accumulation de droits

À RETENIR Collusion : entente entre plusieurs personnes pour contourner la séparation des tâches. La rotation des postes aide à la détecter.

Réussir le départ d'un salarié

Départ normal

- Entretien de sortie : rappel des obligations (NDA)
- Restitution du matériel, des badges, des clés
- Désactivation des comptes le jour du départ

Départ conflictuel

- Désactiver les accès **avant** ou **pendant** l'annonce
- Escorter la personne
- Surveiller les exfiltrations de données récentes

À RETENIR Un compte d'ancien salarié encore actif est une porte ouverte : l'offboarding doit être une procédure formelle, liée aux RH.

Étendre la sécurité à ceux qui ne sont pas salariés

Contrat

Clauses de sécurité, de confidentialité et de réversibilité. **Droit d'audit** du client.

SLA

Accord de niveau de service (*Service Level Agreement*) : disponibilité, délais d'intervention, pénalités.

Accès

Comptes nominatifs, limités dans le temps et au strict nécessaire. Surveillance des accès à distance.

À RETENIR Un consultant a souvent autant d'accès qu'un salarié, mais moins de contrôles : c'est un risque fréquent.

05

CHAPITRE 05

Gestion des risques

Identifier, mesurer et traiter les risques pour décider en connaissance de cause.

- Le vocabulaire du risque
- Analyse qualitative et quantitative
- Traiter un risque
- Catégories et fonctions des contrôles
- Méthodes : NIST RMF, ISO 27005, EBIOS RM

Les mots à maîtriser absolument

Terme	Définition simple	Exemple
Actif (Asset)	Tout ce qui a de la valeur pour l'organisation	Base clients, serveur, réputation
Menace (Threat)	Événement ou action qui peut causer un dommage	Rançongiciel, incendie, erreur humaine
Agent de menace	Personne ou chose qui réalise la menace	Cybercriminel, salarié, orage
Vulnérabilité	Faiblesse qui peut être exploitée par une menace	Logiciel non mis à jour
Exposition	Situation où l'actif peut subir une perte	Serveur accessible depuis Internet

Suite du vocabulaire

Terme	Définition simple	Exemple
Risque	Probabilité qu'une menace exploite une vulnérabilité, combinée à l'impact	Chiffrement de la base clients par un rançongiciel
Contre-mesure	Mesure qui réduit le risque (aussi : contrôle, protection)	Correctif, sauvegarde, MFA
Attaque	Tentative volontaire d'exploiter une vulnérabilité	Envoi d'un e-mail piégé
Violation (Breach)	Attaque réussie : un contrôle a été contourné	Données volées
Incident	Événement qui nuit à la sécurité	Poste infecté détecté par l'antivirus

À RETENIR Sans vulnérabilité, une menace ne peut rien. Sans menace, une vulnérabilité ne coûte rien. Le risque naît de leur rencontre.

Comment raisonner sur un risque

Risque = Menace × Vulnérabilité

Le risque

On peut ajouter l'impact : un risque grave est probable ET coûteux.

Risque = Probabilité × Impact

Autre écriture courante

Utilisée dans les matrices de risques qualitatives.

Menaces × Vulnérabilités × Valeur

Le risque total

Le risque avant toute mesure de sécurité.

Risque total – contrôles

Le risque résiduel

Ce qui reste une fois les mesures en place.

À RETENIR Le risque résiduel n'est jamais nul. La direction doit l'accepter de façon explicite et formelle.

Quatre notions pour piloter le risque

Inherent risk

Risque inhérent

Le risque **avant** toute mesure de sécurité.

Residual risk

Risque résiduel

Le risque qui **reste** après les mesures.

Risk appetite

Appétence au risque

Quantité de risque que l'organisation est **prête à prendre** pour atteindre ses objectifs.

Risk tolerance

Tolérance au risque

Écart acceptable autour de l'appétence, pour un objectif précis.

EXEMPLE Une banque a une faible appétence au risque de fraude, une start-up une forte appétence au risque commercial.

Les étapes de la gestion des risques

1 Identifier les actifs
Les recenser et leur donner une valeur.

2 Identifier les menaces
Qui ou quoi peut nuire ?

3 Identifier les vulnérabilités
Où sont les faiblesses ?

4 Évaluer le risque
Probabilité et impact.

5 Traiter le risque
Réduire, transférer, éviter ou accepter.

6 Surveiller
Mesurer, revoir, recommencer.

À RETENIR C'est un cycle : les menaces, les actifs et les technologies changent, donc l'analyse doit être refaite régulièrement.

ÉTAPE 1

Identifier et valoriser les actifs

Actifs tangibles

- Matériel, locaux, équipements
- Valeur facile à chiffrer (prix d'achat, remplacement)

Actifs intangibles

- Données, savoir-faire, réputation, marque
- Valeur difficile à chiffrer, souvent la plus élevée

Critères de valeur

- Coût d'acquisition ou de développement
- Coût de remplacement
- Perte de revenus si indisponible
- Valeur pour un concurrent

À RETENIR On ne protège bien que ce que l'on connaît : l'inventaire des actifs est la base de toute analyse de risques.

Analyse qualitative ou quantitative ?

Des mots

Qualitative

- Utilise des **échelles** : faible, moyen, élevé
- Rapide et simple à comprendre
- Repose sur l'avis d'experts : subjective
- Outils : matrice, méthode Delphi, ateliers

Des chiffres

Quantitative

- Utilise des **montants** en euros et des fréquences
- Permet de comparer coûts et bénéfices
- Demande beaucoup de données fiables
- Outils : SLE, ALE, ROSI

À RETENIR En pratique, on combine les deux (approche hybride) : qualitative pour trier, quantitative pour les risques majeurs.

La matrice probabilité × impact

PROBABILITÉ ↓ · IMPACT →

Très probable	Moyen	Élevé	Critique	Critique
Probable	Faible	Moyen	Élevé	Critique
Possible	Faible	Moyen	Moyen	Élevé
Rare	Faible	Faible	Moyen	Moyen
Mineur	Significatif	Grave	Critique	

Comment la lire ?

Axe vertical : la **probabilité**. Axe horizontal : l'**impact**. La case indique le niveau de risque.

À quoi sert-elle ?

À **classer** les risques et à décider lesquels traiter en premier.

La méthode Delphi

En anglais : Delphi technique

DÉFINITION

Technique de consultation **anonyme** d'un groupe d'experts. Chacun donne son avis par écrit, sans savoir qui a dit quoi. On partage les résultats et on recommence jusqu'à obtenir un consensus.

POURQUOI L'ANONYMAT ?

Pour éviter qu'un expert influence les autres par son rang ou sa personnalité.

EXEMPLE

Cinq experts évaluent l'impact d'une fuite de données : 3 tours suffisent pour converger vers « élevé ».

Cinq formules de base

Sigle	Nom complet	Définition	Calcul
AV	Valeur de l'actif (Asset Value)	Valeur en euros de l'actif	—
EF	Facteur d'exposition (Exposure Factor)	Pourcentage de l'actif perdu lors d'un incident	en %
SLE	Perte unitaire (Single Loss Expectancy)	Coût d'un seul incident	$AV \times EF$
ARO	Fréquence annuelle (Annualized Rate of Occurrence)	Nombre d'incidents attendus par an	ex. 0,5 = tous les 2 ans
ALE	Perte annuelle (Annualized Loss Expectancy)	Coût moyen des incidents par an	$SLE \times ARO$

À RETENIR Retenez la chaîne : $AV \times EF = SLE$, puis $SLE \times ARO = ALE$.

EXEMPLE CHIFFRÉ

Un serveur de commandes face aux inondations

$$AV = 200\ 000\ €$$

Valeur de l'actif (AV)

Serveur, données et remise en service.

$$EF = 40\ \%$$

Facteur d'exposition (EF)

Une inondation détruit 40 % de la valeur.

$$SLE = 80\ 000\ €$$

Perte unitaire (SLE)

$200\ 000\ € \times 40\ \%$.

$$ARO = 0,5$$

Fréquence annuelle (ARO)

Une inondation tous les deux ans.

$$ALE = 40\ 000\ €$$

Perte annuelle (ALE)

$80\ 000\ € \times 0,5$: c'est ce que le risque coûte en moyenne chaque année.

Calculer la valeur d'une contre-mesure

$$\text{Valeur} = \text{ALE}_1 - \text{ALE}_2 - \text{ACS}$$

La formule

ALE_1 = avant la mesure, ALE_2 = après, ACS = coût annuel de la mesure.

$$\text{ALE}_1 = 40\,000 \text{ €}$$

Suite de l'exemple

On déménage le serveur en étage : $\text{ALE}_2 = 10\,000 \text{ €}$.

$$\text{ACS} = 12\,000 \text{ €}$$

Coût annuel

Coût du déménagement réparti sur la durée, plus la maintenance.

$$\text{Valeur} = 18\,000 \text{ €}$$

Résultat

$40\,000 - 10\,000 - 12\,000 > 0$: la mesure est rentable.

À RETENIR Une contre-mesure qui coûte plus cher que la perte qu'elle évite n'est pas justifiée. Si la valeur est négative, on cherche une autre option.

Quatre réponses possibles

Mitigate

Réduire

Mettre en place des mesures pour baisser la probabilité ou l'impact. *Ex. : installer un pare-feu.*

Transfer / Share

Transférer

Faire porter tout ou partie du risque par un tiers. *Ex. : souscrire une cyber-assurance.*

Avoid

Éviter

Arrêter l'activité qui crée le risque. *Ex. : ne pas lancer un service jugé trop risqué.*

Accept

Accepter

Garder le risque en connaissance de cause, avec une décision formelle de la direction.

À RETENIR Ignorer un risque (le rejeter sans décision) n'est JAMAIS une réponse acceptable. Et transférer le risque ne transfère pas la responsabilité.

Trois catégories selon leur nature

Administrative

Administratifs

- Aussi appelés contrôles de gestion
- Politiques, procédures
- Formation, vérifications d'embauche
- Classification des données

Technical / Logical

Techniques

- Aussi appelés contrôles logiques
- Chiffrement, pare-feu
- Authentification, antivirus
- Journalisation

Physical

Physiques

- Protègent les lieux et le matériel
- Clôtures, portes, badges
- Caméras, gardiens
- Extinction incendie

À RETENIR La défense en profondeur combine les trois catégories : un seul type de contrôle ne suffit jamais.

Sept fonctions selon leur rôle

Fonction	Rôle	Exemple
Dissuasif	Décourager l'attaquant	Panneau « site sous vidéosurveillance »
Préventif	Empêcher l'incident	Contrôle d'accès, chiffrement
Détectif	Repérer l'incident	Détection d'intrusion (IDS), journaux
Correctif	Corriger après l'incident	Suppression d'un virus, correctif
De récupération	Restaurer le fonctionnement	Restauration des sauvegardes
Directif	Indiquer le comportement attendu	Politique, affichage de consignes
Compensatoire	Remplacer un contrôle impossible à appliquer	Surveillance renforcée d'un vieux système

Un contrôle a toujours une catégorie ET une fonction

	Préventif	Détectif	Correctif
Administratif	Politique de mots de passe	Revue des droits d'accès	Procédure de réponse aux incidents
Technique	Pare-feu, chiffrement	IDS, SIEM	Antivirus qui supprime un virus
Physique	Serrure, clôture	Caméra, détecteur de mouvement	Extincteur

À RETENIR Une caméra est un contrôle physique ET détectif. Si elle est visible, elle est aussi dissuasive.

Évaluer, surveiller et rendre compte

Évaluer

- Tester que le contrôle fonctionne vraiment
- Audit interne ou externe
- Test d'intrusion

Surveiller

- Mesurer en continu
- **KPI** : indicateur de performance (ex. % de postes à jour)
- **KRI** : indicateur de risque (ex. nombre d'alertes critiques)

Rendre compte

- Tableau de bord pour la direction
- Langage métier, pas technique
- Registre des risques mis à jour

À RETENIR Un contrôle non testé est une hypothèse, pas une protection.

Les méthodes les plus utilisées

Méthode	Origine	Caractéristique
ISO 31000	ISO	Principes généraux de gestion des risques, tous domaines
ISO/IEC 27005	ISO	Gestion des risques liés à la sécurité de l'information (lien avec 27001)
NIST SP 800-37 (RMF)	NIST	Cadre en 7 étapes pour les systèmes d'information
NIST SP 800-30	NIST	Guide pour conduire une appréciation des risques
EBIOS Risk Manager	ANSSI (France)	Méthode française en 5 ateliers, par scénarios
FAIR	The Open Group	Analyse quantitative du risque en valeur financière

Le Risk Management Framework en 7 étapes

1 Préparer
Contexte et priorités.

2 Catégoriser
Évaluer l'impact d'une perte.

3 Sélectionner
Choisir les contrôles.

4 Mettre en œuvre
Déployer et documenter.

5 Évaluer
Vérifier l'efficacité.

6 Autoriser
Un responsable accepte le risque.

7 Surveiller
Suivi continu.

À RETENIR L'étape « Autoriser » illustre un principe clé : un dirigeant accepte formellement le risque résiduel avant la mise en service.

La méthode française en 5 ateliers

1

Cadrage et socle

Périmètre, valeurs métier, événements redoutés, socle de sécurité.

2

Sources de risque

Qui peut attaquer, et pour quel objectif ?

3

Scénarios stratégiques

Chemins d'attaque via l'écosystème (fournisseurs, partenaires).

4

Scénarios opérationnels

Modes opératoires techniques de l'attaquant.

5

Traitement du risque

Plan de sécurité et suivi du risque résiduel.

À RETENIR EBIOS RM est la méthode recommandée en France, notamment pour les administrations et les opérateurs d'importance vitale.

Mesurer la maturité d'un processus (CMMI)

Niveau	Nom	Description
1	Initial	Processus improvisés, résultats imprévisibles
2	Géré	Processus suivis projet par projet
3	Défini	Processus standardisés pour toute l'organisation
4	Géré quantitativement	Processus mesurés par des indicateurs
5	En optimisation	Amélioration continue

À RETENIR Un modèle de maturité aide à dire « où en sommes-nous ? » et « où voulons-nous aller ? ».

Le registre des risques

Registre des risques (*risk register*) : document qui liste tous les risques identifiés, leur évaluation, leur traitement et leur responsable.

Colonne	Contenu
Identifiant et description	R-12 : chiffrement des serveurs par un rançongiciel
Actif concerné et propriétaire	ERP de production · Directeur des opérations
Probabilité et impact	Probable · Critique
Niveau de risque	Critique
Traitement choisi	Réduire : sauvegardes hors ligne, EDR, segmentation
Risque résiduel et échéance	Moyen · accepté par la direction · revue en juin

06

CHAPITRE 06

Modélisation des menaces

Trouver ce qui peut mal tourner, avant que cela n'arrive.

- Définition et questions clés
- Trois approches
- Le processus type
- Les familles de modèles

DÉFINITION

Modélisation des menaces

En anglais : Threat modeling

DÉFINITION

Démarche structurée pour **identifier, classer et prioriser** les menaces qui pèsent sur un système, puis définir les mesures pour les réduire. Elle se fait de préférence **tôt**, dès la conception.

QUATRE QUESTIONS (A. SHOSTACK)

- Sur quoi travaillons-nous ?
- Qu'est-ce qui peut mal tourner ?
- Que faisons-nous contre cela ?
- Avons-nous fait du bon travail ?

À RETENIR

Corriger une faille à la conception coûte bien moins cher que la corriger en production.

Les approches de la modélisation

Asset-centric

Centrée sur les actifs

On part de **ce qui a de la valeur** et on cherche ce qui peut l'atteindre. Ex. : *OCTAVE, Trike*.

Attacker-centric

Centrée sur l'attaquant

On part de **qui peut attaquer**, avec quels moyens et quelle motivation. Ex. : *PASTA, ATT&CK*.

Software-centric

Centrée sur le système

On part de **l'architecture** (composants, flux) et on cherche les faiblesses. Ex. : *STRIDE*.

Six étapes communes à la plupart des modèles

1 Définir le périmètre
Quel système, quels objectifs ?

2 Décomposer
Dessiner un DFD : acteurs, processus, stockages, flux.

3 Tracer les frontières
Où change le niveau de confiance ?

4 Identifier les menaces
Avec une grille (STRIDE, LINDDUN...).

5 Prioriser
Avec une note (DREAD, CVSS...).

6 Réduire et valider
Contre-mesures, puis vérification.

À RETENIR **DFD** (diagramme de flux de données) : schéma qui montre comment l'information circule. **Frontière de confiance** : limite où les données passent d'une zone à une autre (ex. Internet → réseau interne).

NE PAS TOUT MÉLANGER

Quatre familles d'outils

Famille	Question traitée	Exemples
Grilles d'identification	Quelles menaces chercher ?	STRIDE, LINDDUN, arbres d'attaque
Méthodes complètes	Comment mener toute la démarche ?	PASTA, OCTAVE, Trike, VAST, CORAS
Bases de connaissances	Comment les attaquants agissent-ils vraiment ?	MITRE ATT&CK
Systèmes de notation	Quelle menace traiter en premier ?	DREAD, CVSS

À RETENIR CVSS et ATT&CK ne sont pas des méthodes de modélisation au sens strict, mais des outils qui les complètent.

07

CHAPITRE 07

Chaîne d'approvisionnement

Vos fournisseurs font partie de votre surface d'attaque.

- Définition et exemples d'attaques
- Mesures de maîtrise
- Les rapports SOC

DÉFINITION

Gestion des risques de la chaîne d'approvisionnement

En anglais : Supply Chain Risk Management (SCRM)

DÉFINITION

Démarche qui identifie et réduit les risques venant des **fournisseurs, prestataires et composants** (matériel, logiciels, services cloud) dont dépend l'organisation.

RISQUES TYPIQUES

- Logiciel piégé lors d'une mise à jour
- Composant matériel contrefait
- Faillite ou panne d'un fournisseur clé
- Dépendance à un seul fournisseur

EXEMPLES RÉELS

- SolarWinds (2020) : mise à jour piégée
- 3CX (2023) : logiciel compromis
- XZ Utils (2024) : porte dérobée dans une bibliothèque open source

Les mesures principales

Avant le contrat

- Évaluer le fournisseur (questionnaire, audit)
- Vérifier ses certifications (ISO 27001, SOC 2)
- Définir des exigences minimales de sécurité

Dans le contrat

- Clauses de sécurité et de notification d'incident
- SLA et pénalités
- Droit d'audit et réversibilité

Pendant la relation

- Surveiller le fournisseur
- Exiger un **SBOM** pour les logiciels
- Revoir les accès et les contrats

À RETENIR **SBOM** (Software Bill of Materials) : la « liste des ingrédients » d'un logiciel, c'est-à-dire tous ses composants et bibliothèques.

Les rapports SOC

Type I : décrit les contrôles à une date donnée (sont-ils bien conçus ?). **Type II** : les teste sur une période de plusieurs mois (fonctionnent-ils vraiment ?).

Rapport	Contenu	Destinataire
SOC 1	Contrôles qui touchent la fiabilité des états financiers du client	Auditeurs financiers du client
SOC 2	Contrôles liés à la sécurité, la disponibilité, l'intégrité du traitement, la confidentialité, la vie privée	Clients (rapport confidentiel)
SOC 3	Résumé du SOC 2, sans les détails	Public (publicité, site web)

À RETENIR Pour choisir un fournisseur cloud, demandez un rapport SOC 2 Type II : c'est le plus exigeant.

08

CHAPITRE 08

Sensibilisation et formation

Transformer le « maillon faible » en première ligne de défense.

- Sensibilisation, formation, éducation
- Ingénierie sociale
- Méthodes et mesure de l'efficacité

TROIS NIVEAUX

Sensibilisation, formation et éducation

Niveau	Objectif	Public	Exemple
Sensibilisation (Awareness)	Faire connaître les risques	Tout le personnel	Affiches, courtes vidéos, e-mails
Formation (Training)	Apprendre à faire une tâche en sécurité	Personnes selon leur poste	Atelier sur le développement sécurisé
Éducation (Education)	Faire comprendre en profondeur	Spécialistes	Master, certification CISSP

À RETENIR Sensibiliser = « quoi ». Former = « comment ». Éduquer = « pourquoi ».

Les techniques d'ingénierie sociale

Technique	Définition
Hameçonnage (phishing)	E-mail frauduleux envoyé en masse pour voler des informations
Harponnage (spear phishing)	Hameçonnage ciblé sur une personne précise
Whaling	Harponnage visant un dirigeant (« gros poisson »)
Vishing / Smishing	Arnaque par téléphone (voix) ou par SMS
Prétexte (pretexting)	Scénario inventé pour obtenir la confiance (faux technicien)
Talonnage (tailgating)	Entrer dans un bâtiment en suivant une personne autorisée

À RETENIR Ces attaques jouent sur les émotions : urgence, peur, autorité, curiosité. Le bon réflexe : prendre le temps de vérifier.

Méthodes et mesure

Méthodes

- Simulations d'hameçonnage
- Jeux et défis (gamification)
- Réseau de « champions » de la sécurité
- Contenus courts et réguliers

Mesurer

- Taux de clic sur les simulations
- Taux de signalement des e-mails suspects
- Résultats des quiz
- Nombre d'incidents liés à l'humain

Entretenir

- Mettre à jour les contenus chaque année
- Adapter aux nouvelles menaces (deepfakes, IA)
- Adapter au métier de chacun

À RETENIR Le bon indicateur n'est pas seulement « combien ont cliqué », mais « combien ont signalé ».

09

CHAPITRE 09

Continuité d'activité

Continuer à fonctionner malgré un incident majeur.

- PCA et PRA
- L'analyse d'impact sur l'activité (BIA)
- Les indicateurs MTD, RTO, RPO, WRT
- Les étapes d'un projet de continuité

PCA et PRA : quelle différence ?

BCP • Business Continuity Plan

PCA • Plan de continuité d'activité

Garantir que les **activités essentielles** continuent pendant et après un incident majeur. Il concerne toute l'organisation (personnes, locaux, processus).

DRP • Disaster Recovery Plan

PRA • Plan de reprise d'activité

Rétablir les **systèmes informatiques** après un sinistre. C'est une partie technique du PCA.

À RETENIR Le PCA protège le métier ; le PRA remet l'informatique en route. La sécurité des personnes reste la priorité absolue.

Analyse d'impact sur l'activité

En anglais : Business Impact Analysis (BIA)

DÉFINITION

Étude qui identifie les **activités critiques** de l'organisation et mesure l'impact de leur arrêt dans le temps (financier, légal, image). Elle fixe les délais maximaux d'interruption.

LES ÉTAPES

- Identifier les processus métier et leurs dépendances
- Évaluer l'impact d'un arrêt (1 h, 1 jour, 1 semaine...)
- Fixer la priorité de reprise

EXEMPLE

Pour un hôpital, les dossiers patients sont critiques ; l'intranet d'actualités ne l'est pas.

LES INDICATEURS DE LA CONTINUITÉ

MTD, RTO, RPO, WRT

Sigle	Nom	Question posée
MTD	Durée maximale d'interruption tolérable (Maximum Tolerable Downtime)	Au-delà de quelle durée l'arrêt met-il l'entreprise en danger ?
RTO	Délai de reprise (Recovery Time Objective)	En combien de temps doit-on remettre le système en route ?
RPO	Perte de données maximale (Recovery Point Objective)	Combien de données (en temps) peut-on perdre ? Définit la fréquence des sauvegardes.
WRT	Temps de vérification (Work Recovery Time)	Combien de temps pour tester et reprendre le travail ?

À RETENIR Règle à retenir : $RTO + WRT \leq MTD$. Exemple : RPO de 4 h = une sauvegarde au moins toutes les 4 heures.

Les grandes étapes d'un PCA

1 Initier le projet
Soutien de la direction, périmètre, équipe.

2 Réaliser la BIA
Activités critiques, MTD, RTO, RPO.

3 Choisir les stratégies
Site de secours, sauvegardes, redondance.

4 Rédiger le plan
Rôles, procédures, communication.

5 Tester et former
Exercices sur table, simulations.

6 Maintenir
Mise à jour à chaque changement.

À RETENIR Un plan jamais testé ne fonctionne pas le jour J. Les tests vont de la simple relecture à l'interruption complète.

10

CHAPITRE 10

Les modèles de menaces

Synthèse des présentations individuelles du 9 septembre après-midi.

- Une fiche par modèle présenté
- Tableau comparatif
- Comment choisir et combiner les modèles

Onze modèles présentés en classe

Modèle	Famille	Présenté par
STRIDE	Grille d'identification	David AMARO MONTEIRO
DREAD	Notation / priorisation	Louis HAMARD
PASTA	Méthode complète, centrée attaquant	Thomas GUILLAUDEUX
OCTAVE	Méthode complète, centrée actifs	Steven STANGRECIK
Trike	Méthode complète, centrée risque	Melvin RAIMBAULT
VAST	Méthode complète, industrialisée	Nicolas APPERT
LINDDUN	Grille d'identification (vie privée)	Alexandre BRASSIER
CORAS	Méthode complète, graphique	Lucas HUARD
Arbres d'attaque	Grille d'identification (objectif)	Jules DEMEURE
MITRE ATT&CK	Base de connaissances	Titouan DREVILLON
CVSS	Notation des vulnérabilités	Corentin LAFRANCHE

STRIDE : six catégories de menaces

Origine

Créé chez **Microsoft** vers 1999 par Loren Kohnfelder et Praerit Garg.

Principe

On applique six questions à chaque élément d'un DFD : peut-on usurper ? modifier ? nier ? divulguer ? bloquer ? élever ses droits ?

Quand l'utiliser ?

Dès la **conception** d'une application, avec les développeurs. Simple et rapide à apprendre.

À RETENIR STRIDE dit **quoi chercher**, mais pas comment prioriser : on l'associe souvent à DREAD ou CVSS.

Chaque menace viole une propriété de sécurité

Menace	Propriété violée	Exemple	Contre-mesure
Spoofing · usurpation	Authenticité	Mot de passe volé	MFA, certificats
Tampering · falsification	Intégrité	Montant d'un virement modifié	Signature, hachage
Repudiation · répudiation	Non-répudiation	Action impossible à attribuer	Journaux horodatés
Information disclosure	Confidentialité	Données exposées par une API	Chiffrement, contrôle d'accès
Denial of service	Disponibilité	Serveur saturé	Limitation de débit, redondance
Elevation of privilege	Autorisation	Un utilisateur devient admin	Moindre privilège

À RETENIR Astuce : STRIDE est le « miroir » des propriétés de sécurité vues au chapitre 01.

DREAD : noter une menace sur cinq critères

Créé chez **Microsoft** (début des années 2000). Chaque critère reçoit une note (par exemple de 1 à 10) ; la **moyenne** donne le niveau de risque.

Critère	Question posée
Damage · dommages	Quelle est la gravité des dégâts si l'attaque réussit ?
Reproducibility · reproductibilité	L'attaque est-elle facile à reproduire ?
Exploitability · exploitabilité	Faut-il beaucoup de compétences ou de moyens ?
Affected users · utilisateurs touchés	Combien de personnes sont concernées ?
Discoverability · découvrabilité	La faille est-elle facile à trouver ?

À RETENIR Limite : les notes sont subjectives. Microsoft a cessé de l'utiliser en interne, mais DREAD reste utile pour trier rapidement.

PASTA : sept étapes, du métier à l'attaque

- | | |
|---|---|
| 1 Définir les objectifs
Objectifs métier et exigences de conformité. | 2 Définir le périmètre technique
Composants, technologies, dépendances. |
| 3 Décomposer l'application
Flux de données, rôles, frontières de confiance. | 4 Analyser les menaces
Renseignement sur les menaces réelles. |
| 5 Analyser les vulnérabilités
Faiblesses existantes et leurs liens aux menaces. | 6 Modéliser les attaques
Arbres d'attaque, scénarios, simulations. |
| 7 Analyser risques et impacts
Impact métier et contre-mesures prioritaires. | |

À RETENIR Process for **A**ttack **S**imulation and **T**hreat **A**nalysis (UcedaVélez et Morana, 2012–2015). Méthode centrée sur l'attaquant et **alignée sur le métier**.

OCTAVE : une évaluation centrée sur les actifs

Origine

SEI et CERT de l'université Carnegie Mellon, à partir de 1999. Variantes : OCTAVE-S (petites structures), OCTAVE Allegro (2007, allégée).

Trois phases

- Profils de menaces par actif (vue organisation)
- Vulnérabilités de l'infrastructure (vue technique)
- Stratégie et plans de sécurité

Points forts

- Menée par une équipe interne
- Relie cyber et enjeux métier
- Prend en compte l'humain et l'organisation

À RETENIR Nom complet : **O**perationally **C**ritical **T**hreat, **A**sset, and **V**ulnerability **E**valuation. Plus adaptée à l'organisation qu'à une application.

Trike : partir des droits d'accès

Origine

Méthode **open source** publiée en 2005 par Paul Saitta, Brenda Larcom et Michael Eddington.

Principe

Une matrice **acteurs × actifs × actions** (créer, lire, modifier, supprimer) décrit ce qui est autorisé. On la compare à ce qui est techniquement possible.

Approche

Défensive et pilotée par le risque : chaque écart entre « permis » et « possible » est une menace.

À RETENIR Force : rigueur et reproductibilité. Limite : méthode lourde, documentation restée à l'état de brouillon, peu d'outils maintenus.

VAST : industrialiser la modélisation

Origine

Visual, **A**gile and **S**imple **T**hreat modeling, créée par Archie Agarwal (ThreatModeler).

Deux types de modèles

- **Applicatif** : diagrammes de flux de processus, pour les développeurs
- **Opérationnel** : vue infrastructure, pour les équipes d'exploitation

Trois piliers

- Automatisation
- Intégration aux flux DevOps
- Collaboration entre équipes

À RETENIR VAST ne remplace pas STRIDE : c'est un cadre pour passer à l'échelle (des centaines d'applications). Il dépend fortement d'un outil commercial.

LINDDUN : les menaces pour la vie privée

Créé à la **KU Leuven** (Belgique) vers 2010 ; première publication en 2011. C'est « le STRIDE de la vie privée ».

Catégorie	Définition
Linking · liaison	Relier plusieurs données ou actions à une même personne
Identifying · identification	Identifier une personne à partir de ses données
Non-repudiation	Ne plus pouvoir nier une action (mauvais pour la vie privée)
Detecting · détection	Déduire la présence ou l'activité d'une personne
Data disclosure · divulgation	Exposer des données personnelles
Unawareness · méconnaissance	La personne ne sait pas ou ne contrôle pas
Non-compliance · non-conformité	Ne pas respecter le RGPD ou les règles

Les arbres d'attaque : partir de l'objectif

Origine

Popularisés par **Bruce Schneier** en 1999.

Principe

- La **racine** est l'objectif de l'attaquant
- Les **branches** sont les moyens d'y arriver
- Nœud **OU** : un seul moyen suffit
- Nœud **ET** : tous sont nécessaires

Enrichir l'arbre

On ajoute à chaque feuille un coût, une difficulté ou une probabilité, pour trouver le **chemin le plus facile**.

EXEMPLE Racine « Voler les données clients » → OU (hameçonner un admin ; exploiter l'API) → ET (trouver la faille ET contourner le pare-feu).

CORAS : l'analyse de risque par les diagrammes

Origine

Projet européen mené par **SINTEF** (Norvège) au début des années 2000. Livre de référence : Lund, Solhaug et Stølen (2011).

Principe

Un **langage graphique** inspiré d'UML : diagrammes d'actifs, de menaces, de risques et de traitements, compris par tous.

Démarche

Environ **8 étapes** : préparation, cadrage avec le client, description de la cible, identification, estimation, évaluation et traitement du risque.

À RETENIR Point fort : les diagrammes facilitent le dialogue entre techniciens et décideurs. Un outil gratuit (CORAS tool) existe.

ATT&CK : ce que font vraiment les attaquants

Définition

Base de connaissances **gratuite** de MITRE (créée en 2013, publique en 2015) qui décrit les comportements réels des attaquants.

Organisation

- **Tactique** : le « pourquoi » (objectif)
- **Technique** : le « comment »
- **Procédure** : la mise en œuvre concrète par un groupe

Usages

- Détection et SOC
- Exercices Red Team / Purple Team
- Mesure de couverture des défenses

À RETENIR La matrice Enterprise compte 14 tactiques, de la Reconnaissance à l'Impact. ATT&CK complète un modèle de menaces avec des scénarios réalistes.

CVSS : un score de 0 à 10 pour chaque vulnérabilité

Common Vulnerability Scoring System, maintenu par le **FIRST**. Version actuelle : **4.0** (2023). Groupes de métriques : Base, Menace (*Threat*), Environnement, Supplémentaire.

Score	Niveau de gravité
0,0	Aucun
0,1 – 3,9	Faible
4,0 – 6,9	Moyen
7,0 – 8,9	Élevé
9,0 – 10,0	Critique

À RETENIR Le score de base mesure la gravité technique, pas le risque pour **votre** organisation : il faut l'ajuster avec les métriques d'environnement.

Deux méthodes de la liste non présentées

hTMM

Hybrid Threat Modeling Method (SEI, Carnegie Mellon, 2018). Combine plusieurs techniques, dont les *Security Cards* (remue-méninges) et les *Persona non Grata* (profils d'attaquants imaginaires).

ASTRA

Méthode proposée dans la liste des sujets, non présentée en séance. À documenter par vos soins si vous la reprenez pour le projet.

À RETENIR CORAS, ATT&CK et CVSS ont été présentés à la place de certains modèles de la liste : ils complètent bien le panorama.

TABEAU COMPARATIF

Quel modèle pour quel besoin ?

Modèle	Point de départ	Effort	Idéal pour...
STRIDE	Système (DFD)	Faible	Concevoir une application
DREAD	Menaces déjà trouvées	Faible	Trier rapidement
PASTA	Métier et attaquant	Élevé	Aligner sécurité et métier
OCTAVE	Actifs	Élevé	Évaluer toute une organisation
Trike	Droits d'accès	Élevé	Audit rigoureux et reproductible
VAST	Processus et infrastructure	Moyen	Grands portefeuilles, DevOps
LINDDUN	Données personnelles	Moyen	Vie privée, RGPD
CORAS	Actifs et parties prenantes	Moyen	Communiquer avec les décideurs
Arbres d'attaque	Objectif de l'attaquant	Moyen	Détailler un scénario
ATT&CK	Comportements réels	Moyen	Détection, exercices
CVSS	Vulnérabilité connue	Faible	Prioriser les correctifs

Partir de la question que l'on se pose

Si votre question est...	...alors utilisez
« Quelles menaces pèsent sur cette application ? »	STRIDE
« Quels risques pour la vie privée ? »	LINDDUN
« Quel impact pour le métier ? »	PASTA ou OCTAVE
« Comment un attaquant atteindrait-il ce but ? »	Arbres d'attaque
« Que font les vrais attaquants ? »	MITRE ATT&CK
« Par quoi commencer ? »	DREAD ou CVSS
« Comment le faire sur 200 applications ? »	VAST

À RETENIR Il n'existe pas de « meilleur » modèle : il existe un modèle adapté à une question, un contexte et des moyens.

Une chaîne complète, de la conception au traitement

1

Décrire

DFD du système et frontières de confiance.

2

Identifier

STRIDE (et LINDDUN si données personnelles).

3

Détailler

Arbres d'attaque, enrichis avec ATT&CK.

4

Prioriser

CVSS ou DREAD.

5

Traiter

Réduire, transférer, éviter ou accepter (chap. 05).

À RETENIR C'est exactement la démarche que vous mettrez en œuvre dans le projet « Agents IA » de la prochaine séance.

11

CHAPITRE 11

Réviser

Vérifier ses acquis avant la prochaine séance.

- Les 10 idées à retenir
- Glossaire français-anglais
- Quiz corrigé
- Préparer le projet Agents IA

Les 10 idées à retenir

N°	Idée clé
1	La sécurité protège la confidentialité, l'intégrité et la disponibilité (CIA).
2	Elle sert le métier : la direction décide et reste responsable.
3	Politique (pourquoi) → norme (quoi) → procédure (comment). Seule la ligne directrice est facultative.
4	Due diligence = s'informer ; due care = agir.
5	La conformité (RGPD, NIS2...) est un minimum, pas une garantie de sécurité.
6	Risque = menace × vulnérabilité (× impact). Le risque zéro n'existe pas.
7	$SLE = AV \times EF$; $ALE = SLE \times ARO$.
8	Quatre traitements : réduire, transférer, éviter, accepter. Jamais ignorer.
9	Un contrôle a une catégorie (administratif, technique, physique) et une fonction.
10	Modéliser les menaces tôt, et choisir le modèle selon la question posée.

Français – anglais

Français	Anglais	En une phrase
Confidentialité	Confidentiality	Seules les personnes autorisées lisent
Intégrité	Integrity	L'information reste exacte
Disponibilité	Availability	Accessible quand il le faut
Non-répudiation	Nonrepudiation	Impossible de nier une action
Moindre privilège	Least privilege	Juste les droits nécessaires
Séparation des tâches	Separation of duties	Aucune personne seule pour une tâche sensible
Diligence raisonnable	Due diligence	S'informer avant d'agir
Prudence raisonnable	Due care	Agir comme une personne raisonnable
Ligne directrice	Guideline	Recommandation facultative

Français – anglais

Français	Anglais	En une phrase
Actif	Asset	Ce qui a de la valeur
Menace	Threat	Ce qui peut causer un dommage
Vulnérabilité	Vulnerability	Faiblesse exploitable
Risque résiduel	Residual risk	Ce qui reste après les mesures
Perte annuelle attendue	ALE	Coût moyen du risque par an
Contre-mesure	Countermeasure / Safeguard	Mesure qui réduit le risque
Modélisation des menaces	Threat modeling	Trouver ce qui peut mal tourner
Frontière de confiance	Trust boundary	Limite entre deux zones de confiance
Plan de continuité d'activité	Business Continuity Plan	Continuer malgré un sinistre

Quiz : dix questions pour vérifier vos acquis

1. Un salarié modifie le montant d'une facture sans autorisation. Quelle propriété est violée ?
2. Quel document de la pyramide documentaire est facultatif ?
3. Réaliser une analyse de risques avant de choisir un fournisseur relève-t-il du due care ou de la due diligence ?
4. Un actif vaut 50 000 €, EF = 20 %, ARO = 2. Calculez l'ALE.
5. Souscrire une cyber-assurance : quel traitement du risque ?

6. Une caméra visible : quelle catégorie et quelles fonctions ?
7. Quel délai pour notifier une violation de données à la CNIL ?
8. Quel modèle choisir pour analyser les risques pour la vie privée ?
9. Dans STRIDE, que signifie le « R » ?
10. Que mesure le RPO ?

CONSIGNE Répondez sans regarder vos notes, puis vérifiez avec le corrigé de la page suivante.

Réponses

N°	Réponse
1	L'intégrité (altération non autorisée).
2	La ligne directrice (guideline).
3	Due diligence : on s'informe avant d'agir.
4	$SLE = 50\,000 \times 20\% = 10\,000\text{ €}$; $ALE = 10\,000 \times 2 = 20\,000\text{ €}$.
5	Transférer (ou partager) le risque. La responsabilité, elle, reste à l'entreprise.
6	Contrôle physique, à la fois détectif et dissuasif.
7	72 heures après en avoir pris connaissance.
8	LINDDUN.
9	Repudiation : la possibilité de nier une action. Contre-mesure : journaux horodatés.
10	La perte de données maximale acceptable, exprimée en temps. Il fixe la fréquence des sauvegardes.

Projet : des agents IA pour évaluer le risque

L'idée

Concevoir un système d'**agents IA** qui assiste une analyse de risques : identifier les actifs, choisir un modèle de menaces, lister et prioriser les menaces, proposer un traitement.

Questions pour préparer

- Quelles étapes du chapitre 05 confier à un agent ?
- Quel modèle (STRIDE, PASTA...) l'agent doit-il utiliser, et pourquoi ?
- Comment l'humain valide-t-il les résultats ?

Et les risques de l'IA ?

- Hallucinations et erreurs
- Injection de prompt, fuite de données
- Qui est responsable de la décision finale ?

À RETENIR Appliquez au projet lui-même ce que vous avez appris : un agent IA est un actif, avec ses propres menaces et vulnérabilités.

Sources et références

Thème	Référence
CISSP	ISC2, CISSP Certification Exam Outline (avril 2024) ; ISC2 Code of Ethics
Référentiels	ISO/IEC 27001:2022 et 27002:2022 ; NIST CSF 2.0 (2024) ; NIST SP 800-37 rév. 2 ; SP 800-30
Méthodes françaises	ANSSI, EBIOS Risk Manager (2018) ; CNIL, guides RGPD et AIPD
Modélisation	A. Shostack, Threat Modeling: Designing for Security (2014) ; MITRE ATT&CK ; FIRST, CVSS v4.0
Vie privée	LINDDUN (KU Leuven) ; Règlement (UE) 2016/679 (RGPD)
Présentations	Supports des étudiants du M2, séance du 9 septembre 2026